

Footprinting, Reconnaissance & Active Scanning

Table of Contents

Part 1: Footprinting & Passive Reconnaissance (Class 1)

- Step 1: What is Footprinting?
- Step 2: Types of Reconnaissance
- Step 3: Advanced Google Hacking (Google Dorking)
- Step 4: Google Hacking Database (GHDB)
- Step 5: SHODAN
- Step 6: Internet Archive
- Step 7: WHOIS Protocol & Lookup
- Step 8: Domain Lookup Tools
- Step 9: DNS Reconnaissance Tools

Part 2: Active Reconnaissance & Scanning (Class 2)

- Step 10: What is Active Reconnaissance?
- Step 11: Network Scanning Concepts
- Step 12: Understanding Ports
- Step 13: Well-Known Ports
- Step 14: Port States
- Step 15: Nmap (Network Mapper)
- Step 16: Masscan
- Step 17: Netcat

- Step 18: ARP-Scan
- Step 19: Netdiscover
- Step 20: nmapAutomator
- Step 21: Zenmap, Angry IP Scanner & NetScanTools

Quick Reference: Port Numbers & Nmap Cheat Sheet

Part 1: Footprinting & Passive Reconnaissance

This section covers Class 1 material. Passive reconnaissance is about gathering information without directly interacting with the target. The target has no way of knowing you are investigating them.

Step 1: What is Footprinting?

Footprinting (also called Reconnaissance or Information Gathering) is the first phase of ethical hacking. Before attempting to break into any system, a security professional needs to understand the target thoroughly.

Definition: The process of collecting information about a target system, network, organization, or individual to build a profile or blueprint.

The goal of footprinting is to answer three fundamental questions:

1. What is the target? (Domain names, IP ranges, technologies used)
2. How does it operate? (Network architecture, services, employees)
3. Where might it be vulnerable? (Exposed services, outdated software, misconfigurations)

✓ **TIP:** Think of footprinting like a detective building a case file before an investigation. The more information you gather upfront, the more effective your approach will be.

Step 2: Types of Reconnaissance

Reconnaissance is divided into two main categories based on whether you directly interact with the target.

Aspect	Passive Reconnaissance	Active Reconnaissance
Definition	Gathering information without touching the target	Directly interacting with the target system
Detection Risk	Zero — target cannot detect you	High — target can log and detect your activity
Analogy	Looking at a house from across the street with binoculars	Walking up to the house and trying every door handle
Examples	WHOIS, Google Dorking, Shodan, Internet Archive, Social Media	Nmap scanning, Ping sweep, Traceroute, Social Engineering
Legal Risk	Generally lower (using public data)	Higher (directly probing systems requires authorization)

Passive Reconnaissance Techniques:

- WHOIS Lookup — Find who registered a domain
- DNS Record Lookup — Find IP addresses and mail servers
- Search Engine Research — Google dorking for exposed information
- Internet Research — Wayback Machine, public databases
- Social Networking — LinkedIn, Facebook for employee information

Active Reconnaissance Techniques:

- Ping Sweep / Traceroute — Discover live hosts and network path
- Port Scanning — Find open ports (Nmap, Masscan)
- Network Scanning — Map the entire network
- Social Engineering — Calling employees, phishing emails
- DNS Footprinting — Zone transfers, brute-force subdomain enumeration

Step 3: Advanced Google Hacking (Google Dorking)

Google Hacking (or Google Dorking) is a technique that uses advanced Google search operators to discover sensitive, hidden, or misconfigured information that is publicly available on the internet but not easily visible through normal searches.

Syntax: operator:keyword (no space between operator and keyword)

Common Google Hacking Operators

Operator	What It Does	Example
site:	Restricts results to a specific domain	site:ostad.app
inurl:	Searches for keywords in the URL	inurl:login
intitle:	Searches within page titles	intitle:"index of"
intext:	Searches within page body content	intext:"password"
link:	Finds pages linking to a specific site	link:ostad.app
filetype:	Finds specific file types	filetype:pdf
address: / location:	Searches for address information	address:ostad.app

Combining Operators (Power Searches)

You can combine multiple operators for very targeted searches:

```
site:*.gov filetype:txt intext:"username" intext:"password"
```

This searches government websites for text files containing both "username" and "password" — potentially finding exposed credential files.

```
site:ostad.app inurl:login
```

This finds login pages specifically on ostad.app.

```
intitle:"index of" filetype:pdf
```

This finds exposed directory listings containing PDF files.

⚠ IMPORTANT: Google dorking is legal for finding publicly available information, but using discovered information to gain unauthorized access is illegal. Always have proper authorization.

References: <https://www.googleguide.com> | Google Advanced Search:
https://www.google.com/advanced_search

Step 4: Google Hacking Database (GHDB)

The GHDB (at exploit-db.com/google-hacking-database) is a public archive of curated Google dork strings organized into 14 categories. Security professionals use these to check if their own organization has accidentally exposed sensitive information.

GHDB Categories

4. Footholds — Finding initial access points or exposed entry pages
5. Files Containing Usernames — Locate files that may contain usernames
6. Files Containing Passwords — Identify exposed credentials
7. Sensitive Directories — Discover exposed directory listings
8. Web Server Detection — Identify server type and version
9. Vulnerable Files — Find files known to be vulnerable
10. Vulnerable Servers — Locate servers running vulnerable software
11. Error Messages — Find exposed error pages leaking technical details
12. Files Containing Juicy Info — Locate sensitive operational data
13. Files Containing Emails — Harvest exposed email addresses
14. Documentation — Find internal or public documentation
15. Databases — Detect exposed databases
16. Login Pages — Identify authentication entry points
17. Network or Vulnerability Data — Discover network layouts or scan results

Source: <https://www.exploit-db.com/google-hacking-database>

Step 5: SHODAN

While Google indexes websites (HTTP content), Shodan indexes internet-connected devices. It is often called the "world's first search engine for IoT."

What Shodan Indexes

- Servers, Routers, Cameras, Databases, IoT Devices, Cloud Services

Information Shodan Collects

- IP address and open ports
- Running services (HTTP, FTP, SSH, etc.) with software versions
- Operating system
- Geographic location (country, city)
- SSL certificates
- Organization / ISP
- Response headers

Shodan Search Filters

Filter	Description	Example
port:	Search by port number	port:22
country:	Search by country code	country:BD
org:	Search by organization	org:"Google"
product:	Search by software product	product:Apache
os:	Search by operating system	os:Windows
net:	Search by IP range	net:192.168.1.0/24
hostname:	Search by domain name	hostname:ostad.app
before:/after:	Time-based filtering	before:13/04/2020

Real-World Example from Class

port:3389 country:BD

This search found 4,447 devices in Bangladesh with Remote Desktop Protocol (RDP) exposed to the internet. This is a significant security risk because RDP is a common attack vector for ransomware.

Other Internet-Connected Systems Scanning Tools

18. Shodan — <https://www.shodan.io>
19. Censys — <https://platform.censys.io>
20. ZoomEye — <https://www.zoomeye.ai>
21. FOFA — <https://en.fofa.info>
22. Criminal IP — <https://www.criminalip.io>

Step 6: Internet Archive (Wayback Machine)

The Internet Archive (archive.org) is a non-profit digital archive that stores historical snapshots of websites. In reconnaissance, this is valuable because you can see older versions of a target's website that might have contained information they've since removed.

What It Archives

- Websites, Books, Software, Audio, Video, Historical Internet Data

Limitations

- Not all websites are archived
- Dynamic content (JavaScript-heavy pages) may not load properly
- Website owners can request removal of their archived content

✓ **TIP:** Use the Wayback Machine to check if a target previously published employee directories, old server configurations, deprecated technologies, or contact information that has since been removed.

Site: <https://archive.org/>

Step 7: WHOIS Protocol & Lookup

WHOIS is a text-based TCP protocol (port 43) used to retrieve registration and ownership information of domain names, IP addresses, and ASNs (Autonomous System Numbers).

How WHOIS Works (3-Step Process)

23. WHOIS Client (command-line tool, web service, or security platform) sends a query request
24. WHOIS Server (maintained by domain registrars, ICANN, or Regional Internet Registries) receives the query on TCP port 43
25. Authoritative WHOIS Database stores the actual registration data and returns the response. It may redirect queries to more specific servers.

Information You Can Discover

Domain Information	Owner / Contact Info	IP Address Information
Domain name	Registrant name	ISP / organization
Registrar name	Organization	Network range
Registration date	Email address	Country
Expiration date	Phone number	Abuse contact email
Last updated date	Country	ASN number
Name servers (DNS)	(May be hidden by privacy)	

i NOTE: Many domain owners use WHOIS privacy protection services that hide their personal contact information. You will often see the registrar's privacy service listed instead of the actual owner.

Site: <https://www.whois.com/whois/>

Step 8: Domain Lookup Sites, Tools & Extensions

Here are the key tools and websites for domain investigation covered in the course:

#	Tool / Site	URL / Reference
1	Netcraft	https://sitereport.netcraft.com
2	ICANN Lookup	https://lookup.icann.org/en/lookup
3	DomainTools	https://whois.domaintools.com
4	Whois	https://www.whois.com/whois
5	DNSDumpster	https://dnsdumpster.com
6	whois (CLI tool)	https://www.kali.org/tools/whois
7	sublist3r (subdomain tool)	https://www.kali.org/tools/sublist3r
8	subfinder (subdomain tool)	https://www.kali.org/tools/subfinder
9	Wappalyzer (browser ext.)	https://www.wappalyzer.com/apps
10	nslookup (CLI tool)	Built into Linux/Windows

Step 9: DNS Reconnaissance Tools

DNS reconnaissance tools help you discover subdomains, map DNS records, test for zone transfer vulnerabilities, and perform reverse lookups. Three key tools from the course:

Fierce

- DNS reconnaissance and brute-force subdomain enumeration
- DNS zone transfer testing (AXFR)
- Internal and external IP range mapping
- Misconfigured/public DNS exposure detection

```
fierce --domain ostad.app
```


DNSrecon

- Full DNS record enumeration (A, AAAA, MX, NS, SOA, TXT, etc.)
- Zone transfer testing (AXFR)
- Subdomain brute-forcing
- Reverse DNS lookup (PTR scanning)

```
dnsrecon -d ostad.app
```

DNSenum

- Full DNS record enumeration
- Zone transfer testing (AXFR)
- Subdomain brute-forcing AND Google scraping
- Reverse DNS lookup (PTR scanning)

```
dnsenum ostad.app
```

NOTE: Zone Transfer (AXFR) is a DNS mechanism that replicates DNS records between servers. If misconfigured, an attacker can download the entire DNS zone file, revealing all subdomains and internal infrastructure.

Part 2: Active Reconnaissance & Scanning

This section covers Class 2 material. Active reconnaissance involves directly interacting with target systems to gather information. Unlike passive recon, your activities can be detected and logged.

Step 10: What is Active Reconnaissance?

Active reconnaissance is a technique where an attacker (or ethical hacker) directly interacts with a target system to gather information. It involves three main approaches:

26. Scanning — Sending packets to discover open ports, services, and vulnerabilities
27. Physical Security Testing — Physically testing access controls (badge cloning, tailgating)
28. Social Engineering — Manipulating people to reveal information (phishing, pretexting)

⚠ **IMPORTANT:** Active reconnaissance **MUST** only be performed with proper written authorization. Unauthorized scanning of systems you do not own is illegal in most jurisdictions.

Step 11: Network Scanning Concepts

Network scanning is the process of sending ARP or TCP/IP probes to a network and analyzing the responses to discover:

Discovery Target	Question Answered
Live Hosts	How many hosts are active on the network?
IP Addresses	What are the IP addresses of live hosts?
Open Ports	Which ports are open on each host?
Running Services	Which services are running and what are their versions?
Operating Systems	What OS is running on each machine?
Vulnerabilities	What potential vulnerabilities exist?

The process works like this: the attacker sends probes (ARP requests on local networks, TCP/IP packets across networks) to the target network, and the network responds with information that reveals its structure and services.

Step 12: Understanding Ports

A port is a Transport Layer component — a virtual doorway through which data enters or leaves a device. It works alongside an IP address to direct traffic to the correct application or service.

Analogy: If an IP address is like a building's street address, then a port is like an apartment number inside that building. The IP gets the data to the right machine; the port gets it to the right application.

Port Ranges

Range	Name	Description
0 – 1,023	Well-Known / System Ports	Reserved for common services (HTTP, SSH, DNS, etc.)

1,024 – 49,151	Registered / User Ports	Assigned to specific applications (MySQL 3306, PostgreSQL 5432)
49,152 – 65,535	Dynamic / Private Ports	Used temporarily by the OS for outbound connections

Reference: <https://www.iana.org/assignments/service-names-port-numbers>

Step 13: Well-Known Ports You Must Memorize

These are the most commonly tested ports in cybersecurity. Learn both the insecure and secure versions:

Port	Protocol	Secure Port	Secure Protocol
80	HTTP (Web)	443	HTTPS
23	Telnet	22	SSH / SFTP
21 & 20	FTP (File Transfer)	990 & 989	FTPS
25	SMTP (Email Sending)	465	SMTPS
143	IMAP (Email Retrieval)	993	IMAPS
110	POP3 (Email Retrieval)	995	POP3S
67 & 68	DHCP	546 & 547	DHCPv6
53	DNS	123	NTP (different service)
161 & 162	SNMP	445	SMB (different service)
69	TFTP	3389	RDP (different service)

✓ **TIP:** Notice the pattern: insecure protocols (HTTP, Telnet, FTP) typically have secure counterparts (HTTPS, SSH, FTPS) on different port numbers. The secure versions add encryption (usually via TLS/SSL).

Step 14: Port States (What Nmap Reports)

When Nmap scans a port, it classifies the port into one of three states:

State	Meaning	What It Tells You
-------	---------	-------------------

Open	A service is actively listening on this port	You can connect to this service. It may be a potential entry point.
Closed	No service is listening, but the port is reachable	The port is not blocked by a firewall, but nothing is running on it.
Filtered	Nmap cannot determine if the port is open or closed	A firewall or filter is blocking the probe. The port is inaccessible.

i NOTE: There are also less common states: open|filtered (Nmap can't tell if open or filtered), closed|filtered, and unfiltered (port is accessible but Nmap can't determine if open or closed).

Step 15: Nmap (Network Mapper)

Nmap is the most widely used network scanning tool in cybersecurity. It is an open-source tool that handles host discovery, port scanning, service/version detection, OS detection, and scripting.

Nmap Key Capabilities

- 29. Host Discovery — Find which machines are alive on a network
- 30. Port Scanning — Discover which ports are open on a host
- 31. Service and Version Detection — Identify what software is running behind each open port
- 32. Operating System Detection — Fingerprint the target's OS
- 33. Nmap Scripting Engine (NSE) — Run automated scripts for vulnerability detection and more

Common Nmap Parameters

Parameter	Name	What It Does	Requires Root?
-sS	SYN Scan (Stealth)	Sends SYN, reads response, sends RST. Never completes TCP handshake.	Yes
-sT	TCP Connect Scan	Completes full TCP handshake. More detectable but works without root.	No
-sV	Version Detection	Probes open ports to determine service and software version.	No

-O	OS Detection	Analyzes TCP/IP responses to fingerprint the operating system.	Yes
-A	Aggressive Scan	Combines -O, -sV, -sC (scripts), and traceroute.	Yes
-sU	UDP Scan	Scans UDP ports instead of TCP. Slower but finds DNS, SNMP, etc.	Yes
-sn	Ping Scan (No Port)	Host discovery only. Finds live hosts without scanning ports.	No
-p	Port Specification	Scan specific ports: -p 22,80,443 or range: -p 1-1000	No
-sC	Script Scan	Runs default NSE scripts for common checks.	No
-v	Verbose	Shows more detailed output during scanning.	No
-oN	Normal Output	Saves results to a text file: -oN output.txt	No

Example from Class

```
nmap -O -sV 192.168.182.129
```

This combines OS detection (-O) and version detection (-sV) to scan a Metasploitable VM, revealing 23 open ports with detailed service versions and identifying the OS as Linux 2.6.x.

Website: <https://nmap.org/> | **Kali Reference:** <https://www.kali.org/tools/nmap/>

Step 16: Masscan

Masscan is the fastest Internet port scanner available. It can scan the entire Internet in under 6 minutes by transmitting nearly 10 million packets per second. It uses asynchronous SYN scanning, similar to Nmap's -sS but massively parallelized.

Key Features

- Fastest port scanner available
- Can scan all 65,535 ports on a target very quickly
- Adjustable packet transmission rate
- Can save scan results to files

Example

```
sudo masscan -p1-65535 192.168.177.129 --rate 10000
```

This scans all 65,535 ports at a rate of 10,000 packets per second.

✓ **TIP:** Masscan is great for speed but lacks Nmap's detailed version/OS detection. A common workflow: use Masscan first to quickly find open ports, then use Nmap with `-sV` on those specific ports for detailed analysis.

Step 17: Netcat

Netcat is known as the "TCP/IP Swiss Army Knife." It is a versatile networking utility that can do many things beyond just port scanning.

Key Capabilities

- Port scanning and banner grabbing (reading service identification text)
- Works as both TCP client and server
- File transfer over the network
- Creating reverse and bind shells (used in penetration testing)

Example

```
nc -zv 192.168.177.129 1-65535
```

The `-z` flag means scan mode (don't send data, just check if ports are open) and `-v` means verbose output. This scans all ports on the target.

Step 18: ARP-Scan

ARP-Scan discovers hosts on your local network using ARP (Address Resolution Protocol) packets.

Key Advantages

- Uses ARP protocol — works at Layer 2 (Data Link Layer)
- Works even when hosts block ICMP/Ping requests
- Can choose which network interface to scan from
- Can scan using a custom source MAC address

- Can save scan output to a file

Examples

```
sudo arp-scan -l
```

Scans the local network (automatically detects the subnet).

```
sudo arp-scan --interface=eth0 --localnet
```

Scans the local network using the eth0 interface specifically.

```
sudo arp-scan 192.168.182.0/24
```

Scans a specific subnet range.

i NOTE: ARP-Scan only works on local networks (same Layer 2 broadcast domain). It cannot scan across routers or over the internet.

Step 19: Netdiscover

Netdiscover is similar to ARP-Scan but offers additional features like passive scanning mode.

Key Features

- ARP-based network host discovery
- Passive Scanning Mode — listens for ARP traffic without sending any packets (completely silent)
- Automatic Scanning Mode — detects and scans the local subnet
- Specify network interface and scanning speed

Example

```
sudo netdiscover -r 192.168.182.0/24
```

Actively scans the specified subnet range and displays discovered hosts with their IP, MAC address, and vendor information.

Step 20: nmapAutomator

nmapAutomator is a bash script that wraps around Nmap to automate common scanning workflows. It saves time by running multiple scan types in sequence.

Key Features

- Multiple predefined scan modes (Port, Script, Full, UDP, Vulns, Recon, All)
- Full TCP and UDP scanning automation
- Vulnerability scanning mode
- Automatic service-based recon suggestions

Example

```
nmapAutomator.sh -H 192.168.182.129 -t Port
```

Runs a port scan type against the specified target IP.

GitHub: <https://github.com/21y4d/nmapAutomator>

Step 21: GUI-Based Scanning Tools

Zenmap

Zenmap is the official graphical user interface (GUI) for Nmap.

- Predefined scan profiles for common scan types
- Command builder and command preview
- Network topology mapping (visual diagram of discovered hosts)
- Results database and scan history
- Supports all Nmap features through the GUI

Reference: <https://nmap.org/zenmap/>

Angry IP Scanner

A lightweight, open-source, cross-platform network scanner.

- Fast multi-threaded scanning
- Simple, easy-to-use GUI
- Available on Windows, Mac, and Linux

Reference: <https://angryip.org/>

NetScanTools Pro

A comprehensive Windows-based network tool suite with over 50 tools.

- Advanced port scanning (TCP/UDP)

- Full DNS investigation suite
- Packet capture and traffic analysis
- Automated network data collection (one-click reports)
- Active Directory and LAN diagnostics
- WHOIS and IP ownership research
- Ping, traceroute, and advanced connectivity testing

Reference: <https://www.netscantools.com/>

Quick Reference: Cheat Sheets

Well-Known Ports Quick Reference

Port	Service	Protocol	Description
20, 21	FTP	TCP	File Transfer Protocol (20 = data, 21 = control)
22	SSH / SFTP	TCP	Secure Shell / Secure File Transfer
23	Telnet	TCP	Unencrypted remote access (insecure)
25	SMTP	TCP	Simple Mail Transfer Protocol (sending email)
53	DNS	TCP/UDP	Domain Name System (name resolution)
67, 68	DHCP	UDP	Dynamic Host Configuration Protocol
69	TFTP	UDP	Trivial File Transfer Protocol
80	HTTP	TCP	HyperText Transfer Protocol (web)
110	POP3	TCP	Post Office Protocol v3 (email retrieval)
123	NTP	UDP	Network Time Protocol
143	IMAP	TCP	Internet Message Access Protocol (email)
161, 162	SNMP	UDP	Simple Network Management Protocol
443	HTTPS	TCP	HTTP Secure (encrypted web)
445	SMB	TCP	Server Message Block (file sharing)
465	SMTPS	TCP	SMTP over SSL/TLS
990, 989	FTPS	TCP	FTP over SSL/TLS
993	IMAPS	TCP	IMAP over SSL/TLS

995	POP3S	TCP	POP3 over SSL/TLS
3389	RDP	TCP/UDP	Remote Desktop Protocol

Nmap Commands Cheat Sheet

Command	What It Does
<code>nmap <target></code>	Basic scan of top 1000 ports
<code>nmap -sS <target></code>	SYN (stealth) scan — half-open, fast, less detectable
<code>nmap -sT <target></code>	TCP connect scan — full handshake, works without root
<code>nmap -sV <target></code>	Detect service versions on open ports
<code>nmap -O <target></code>	Detect target operating system (requires sudo)
<code>nmap -A <target></code>	Aggressive scan: OS + version + scripts + traceroute
<code>nmap -sU <target></code>	UDP scan (slower, finds DNS/SNMP/NTP)
<code>nmap -sn <subnet></code>	Ping sweep — find live hosts, no port scan
<code>nmap -p 22,80,443 <target></code>	Scan specific ports only
<code>nmap -p- <target></code>	Scan ALL 65,535 ports
<code>nmap -sC <target></code>	Run default NSE scripts
<code>nmap -v <target></code>	Verbose output — shows more details
<code>nmap -oN output.txt <target></code>	Save results to a text file